

NEXUSTECH SOLUTIONS
Security Policy Development Lifecycle
Practical Laboratory Report

Field	Entry
Student Name	Joan Kemboi
Course	GRC102 – Developing Security Policies and Procedures
Role	Information Security Manager – NexusTech Solutions
Document Version	v1.0

Confidential

Executive Summary

NexusTech Solutions has grown from 50 to 250 employees and now serves high-profile clients in the financial and healthcare sectors. The organisation's existing five-year-old “IT Rules” document combines policy intent, technical instructions and recommendations, resulting in inconsistent practices, unclear accountability and compliance gaps. This report establishes a structured security policy framework and five evidence bundles designed for realistic organisational use.

The framework separates high-level mandatory policy requirements from measurable standards, recommended guidance and operational procedures. It then applies the hierarchy to an Acceptable Use Policy (AUP), a User Access Request Procedure, a communication and training plan, and a policy review and maintenance memo. The artefacts are designed to support governance, risk management, auditability and readiness activities associated with ISO/IEC 27001 and SOC 2.

The assignment brief identifies ISO/IEC 27001:2022, ISO/IEC 27002, NIST CSF 2.0 and SOC 2 Trust Services Criteria as relevant reference resources. ISO describes ISO/IEC 27001 as an ISMS requirements standard that supports risk management and continual improvement; NIST CSF 2.0 provides high-level cybersecurity outcomes for managing and communicating cybersecurity risk; and the AICPA Trust Services Criteria address security, availability, processing integrity, confidentiality and privacy.

Report Structure

Evidence Bundle	Artefact	Marks
1	Policy hierarchy, hierarchy diagram and statement categorisation	20
2	Acceptable Use Policy	25
3	User Access Request Procedure	20
4	Communication and Training Plan	20
5	Policy Review and Maintenance Memo	15

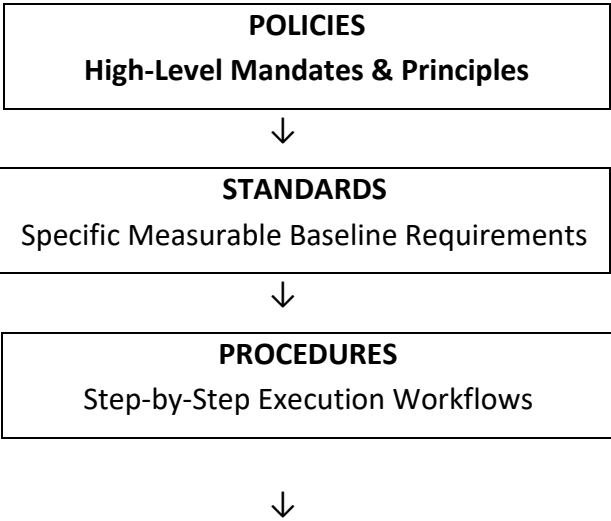
Evidence Bundle 1 – Security Policy Hierarchy

The hierarchy below resolves the documentation problem identified by the IT Director. Each document type has a distinct purpose and level of authority. Mandatory requirements are kept separate from implementation detail so that changes to technology do not unnecessarily require changes to the governing policy.

1.1 Hierarchy Definitions

Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Policy	States management intent, objectives, scope, responsibilities and rules that govern behaviour or risk.	Highest governance authority within the topic.	Mandatory.	High-level; states what and why.
Standard	Defines specific, measurable and enforceable baseline requirements used to implement policy.	Authoritative technical/operational baseline under policy.	Mandatory.	Medium; states measurable requirements.
Guideline	Provides recommended good practices and practical advice where flexibility is appropriate.	Advisory unless explicitly adopted as mandatory.	Recommended.	Medium to detailed; explains preferred approaches.
Procedure	Describes the repeatable sequence of actions required to perform an activity consistently.	Operational instruction derived from policy/standards.	Mandatory when the procedure applies.	Detailed; states how, by whom and in what sequence.

1.2 Policy Hierarchy Diagram



GUIDELINES Recommended Good Practices / Flexible Advice
--

Interpretation: Policy establishes the governing requirement; standards make the requirement measurable; procedures operationalise it; and guidelines help users apply the requirement appropriately where more than one acceptable approach exists.

1.3 Categorisation of the Eight Draft Statements

#	Statement (shortened)	Classification	Justification
1	Remote corporate-network access requires MFA.	Policy	It establishes a mandatory security requirement governing user behaviour and access.
2	Download Authenticator, scan QR code and enter code.	Procedure	It provides sequential instructions for completing a specific technical task.
3	Developers are recommended to use parameterised queries.	Guideline	The wording “recommended” indicates advisory guidance rather than a mandatory baseline.
4	NexusTech is committed to confidentiality, integrity and availability of client data.	Policy	It expresses a high-level management commitment and security principle.
5	Corporate laptops must use BitLocker or FileVault full-disk encryption.	Standard	It defines a specific, measurable baseline technology requirement under a broader policy.
6	Employees should avoid public, unsecured Wi-Fi.	Guideline	The wording “should” presents recommended behaviour rather than an absolute mandatory rule.
7	Suspected breach must be reported immediately to Helpdesk extension 5555.	Procedure	It gives an operational response action and a specific reporting route for an event.
8	Passwords must be at least 14 characters with specified character classes.	Standard	It defines measurable password-control thresholds that can be implemented and tested.

1.4 Governance Observation

The “Password Policy” example should not contain Active Directory reset instructions. The policy should establish the password-management requirement, the associated standard should define measurable password controls, and a procedure should explain how authorised IT personnel perform a reset. This separation improves maintainability, accountability and audit evidence.

Evidence Bundle 2 – Acceptable Use Policy

Document ID: NTS-ISP-AUP-001 | Version: 1.0 | Status: Approved for academic scenario

Policy Owner: Information Security Manager | Approval Authority: Marcus Vance, CEO

Effective Date: 1st October 2026 | Review Date: 1st October 2027

2.1 Purpose

This Acceptable Use Policy (AUP) establishes the rules for responsible, lawful and secure use of NexusTech Solutions information systems, corporate devices, networks, applications and information. It is intended to reduce malware, data-loss, compliance and misuse risks while enabling employees to perform legitimate business activities.

2.2 Scope

This policy applies to all NexusTech employees, contractors, temporary staff, interns and other authorised users who access NexusTech information systems or information. It applies to company-owned or managed devices, approved cloud services, corporate networks, applications, business data and remote-access services.

2.3 Policy Statements

Acceptable business use. Users must use NexusTech systems, devices, networks and information primarily for authorised business purposes and in accordance with their assigned role.

Account responsibility. Users must protect their credentials and must not share passwords, MFA factors, authentication tokens or accounts with another person.

Authorised access. Users must access only systems, applications, information and data for which they have been authorised.

Device security. Users must keep corporate devices physically secure, use required security controls, and promptly report loss, theft or suspected compromise.

Software. Users must not install, download or execute software, browser extensions or scripts on corporate systems unless authorised through NexusTech's approved process.

Malicious activity. Users must not introduce, create, distribute or knowingly execute malware, ransomware, destructive code or other malicious content on NexusTech systems.

Security testing. Users must not conduct vulnerability scanning, penetration testing, exploitation or other security testing against NexusTech or third-party systems unless explicitly authorised.

Data handling. Users must handle client, employee and company information according to its classification and must not disclose sensitive information to unauthorised persons.

Personal cloud storage. Users must not upload, store or transfer NexusTech or client information to personal cloud-storage accounts or other unapproved services.

Prohibited content. Users must not use NexusTech systems to access, store or distribute unlawful, fraudulent, threatening, harassing, discriminatory or otherwise prohibited material.

Network use. Users must not bypass security controls, disable endpoint protections, circumvent access restrictions or attempt to evade monitoring.

Remote work. Users working remotely must use approved access mechanisms and take reasonable precautions to protect information from unauthorised viewing or disclosure.

Email and messaging. Users must exercise caution with links, attachments and requests for sensitive information and must report suspected phishing or social-engineering attempts promptly.

Reasonable personal use. Limited personal use is permitted where it is lawful, occasional, does not interfere with work, does not create material cost or risk, and does not breach this policy or other company requirements.

Prohibited personal use. Personal use must not involve excessive bandwidth or storage consumption, commercial activity unrelated to NexusTech, unauthorised applications, illegal activity, or conduct that exposes NexusTech to material security or compliance risk.

Monitoring. NexusTech may monitor and review use of its systems and network resources to the extent permitted by applicable law and organisational requirements, for security, operational and compliance purposes.

Incident reporting. Users must promptly report suspected security incidents, data loss, phishing, malware, unauthorised access or lost/stolen devices through the approved reporting channel.

2.4 Roles and Responsibilities

Role	Responsibilities
Users	Comply with the AUP; protect credentials and devices; use systems responsibly; report incidents and suspected violations.
Managers	Ensure team members understand applicable requirements; approve legitimate access requests; escalate repeated or material non-compliance.
IT / Security	Implement appropriate technical controls; provide guidance; monitor relevant security events; investigate suspected violations; maintain evidence.
HR	Support onboarding, awareness and disciplinary processes where policy violations involve employee conduct; coordinate with management and Security.
Information Security Manager	Own and maintain the AUP; coordinate review; monitor policy effectiveness; recommend updates and exceptions.

2.5 Compliance and Enforcement

Compliance with this policy is mandatory. Suspected violations may be investigated by authorised personnel. Depending on severity, impact, intent and applicable employment or contractual requirements, consequences may include access restriction, additional training, corrective action, disciplinary measures, contractual remedies or referral to legal or law-enforcement authorities where appropriate. Enforcement should be documented and applied consistently.

2.6 Exceptions

Exceptions must be documented, risk-assessed and approved before the exception is implemented, except where an emergency requires immediate action. The exception record should identify the business justification, affected systems or users, risk, compensating controls, owner, approval, expiry date and review date. Temporary emergency exceptions must be retrospectively documented and reviewed as soon as practicable.

2.7 Approval and Review

Policy Owner: Information Security Manager. Approval Authority: CEO. The policy should be reviewed at least annually and earlier when material changes occur, including significant technology changes, security incidents, regulatory or contractual changes, or identified control weaknesses.

Evidence Bundle 3 – User Access Request Procedure

Document ID: NTS-PR-ACC-001 | Version: 1.0 | Owner: Information Security Manager | Operational
Owner: Helpdesk Manager

3.1 Purpose and Scope

This procedure provides a consistent process for requesting, approving, provisioning, documenting and closing user access to NexusTech systems. It applies to new access, changes to existing access and removal of access.

3.2 Prerequisites

- An approved ticket or workflow in the designated IT service-management system.
- A clearly identified user, manager, requested system/application and business justification.
- Manager approval and, where required, system/data-owner approval.
- An authorised Helpdesk or identity-management technician with the required administrative permissions.
- The applicable role or access profile must be identifiable so that least privilege can be assessed.
- For sensitive or privileged access, the required additional approval and verification must be completed before provisioning.

3.3 Sequential Procedure

Step 1: Receive the request. Confirm that the request was submitted through the approved ticket or workflow. Do not provision access solely from informal email, chat or verbal requests.

Step 2: Validate requester and user. Confirm the identity of the requester and the intended user. Check that the request contains the required business justification and target system.

Step 3: Verify approval. Confirm manager approval and, where applicable, data-owner/system-owner approval. If approval is missing or ambiguous, place the request on hold and obtain the required approval.

Step 4: Determine required role. Map the requested access to an approved role, group or permission profile. Avoid granting broad or administrator-level access when a narrower role satisfies the business requirement.

Step 5: Perform least-privilege check. Compare requested permissions with the user's job responsibilities and existing access. Identify unnecessary, excessive or conflicting privileges before provisioning.

Step 6: Check segregation-of-duties concerns. For sensitive systems, check whether the new access creates a conflict with existing responsibilities or control requirements. Escalate identified conflicts for review.

Step 7: Create or update the account. At a high level, create or update the account using the approved identity-management or application process. Apply the approved role and required authentication controls.

Step 8: Verify provisioning. Confirm that the account has only the approved access. Where technically feasible, validate group membership, role assignment and successful authentication.

Step 9: Notify user and manager. Inform the user that access has been provisioned and communicate any required security responsibilities. Notify the manager where the workflow requires it.

Step 10: Capture evidence. Record approvals, requested role, provisioning action, relevant timestamps, technician identity and validation results in the ticket or linked audit record.

Step 11: Close the ticket. Confirm that the requested outcome has been delivered, evidence is complete and no unresolved issue remains. Close the ticket using the applicable service category and resolution code.

Step 12: Handle emergency requests. For urgent business or security incidents, use the approved emergency-access route. Record the emergency justification, approving authority, temporary permissions and expiry/review time. Retrospectively complete normal documentation.

3.4 Access Removal / Change

Access changes and removals should follow the same principles: approved request, verification of authority, least privilege, timely execution, evidence capture and ticket closure. Termination or transfer-related access changes should be prioritised according to HR and organisational offboarding requirements.

3.5 Records and Audit Trail

Access requests and associated evidence must be retained in the approved service-management or identity-governance record system for the organisation's defined retention period. Records should be sufficiently complete to demonstrate who requested access, who approved it, what was granted, who performed the action, when it occurred and how the result was verified.

Evidence Bundle 4 – Communication and Training Plan

The rollout approach uses multiple channels rather than relying on a PDF email. The plan combines leadership communication, targeted training, acknowledgement, knowledge checks and follow-up monitoring.

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
All employees	The AUP defines acceptable use, prohibited activities, reasonable personal use, data handling and incident-reporting expectations.	CEO announcement; all-hands; intranet; mandatory e-learning	CEO + Security	Week 1	Electronic attestation	≥95% training completion and ≥95% acknowledgement by deadline; knowledge-check results reviewed.
IT / Helpdesk	Users must be supported through approved processes; access and security actions must be authorised and evidenced.	Role-based workshop; procedure walkthrough; job aid	Security + IT Manager	Week 1–2	Training attendance + acknowledgement	100% of Helpdesk staff trained; sample tickets show required approvals/evidence.
Managers	Managers are accountable for reinforcing AUP expectations and approving access appropriately.	Manager briefing; email pack; intranet FAQ	Security + HR	Week 2	Manager attestation	≥95% manager acknowledgement; reduction in approval-related rework.

	y.					
New joiners	AUP requirements apply from onboarding and must be acknowledged before/at access enablement.	Onboarding module; induction checklist	HR + Security	Ongoing	Onboarding attestation	100% of new joiners complete the module and acknowledgment.
Senior management	Management must sponsor enforcement, exception governance and periodic effectiveness review.	Steering Committee briefing; dashboard	Information Security Manager	Monthly / quarterly	Meeting record	Management actions tracked to completion; policy metrics reviewed.

4.1 Rollout Timeline

Period	Activity	Output
Week 1 – Day 1	CEO announcement and publication of approved AUP.	Formal announcement; intranet publication.
Week 1 – Days 2–5	Employee awareness sessions and mandatory e-learning.	Training completion records; questions/FAQ log.
Week 2	IT/Helpdesk and manager role-based sessions.	Attendance and acknowledgement records; job aids.
Week 2–3	Knowledge checks, attestations and targeted reminders.	Knowledge-check and acknowledgement dashboard.
Week 4	First compliance review and sample testing.	Rollout effectiveness report; remediation actions.
Monthly / Quarterly	Monitor incidents, policy questions, exceptions and recurring non-compliance.	Security metrics and management reporting.

4.2 Non-Compliance and Escalation

A missed acknowledgement or training requirement should trigger a reminder and, where appropriate, manager follow-up. Repeated misunderstanding should lead to targeted retraining. Suspected deliberate or material violations should be escalated to the relevant manager, Information Security and HR, according to the nature of the issue. Security-impacting events should also enter the incident-management process.

Evidence Bundle 5 – Policy Review and Maintenance Memo

To: Information Security Steering Committee

From: Information Security Manager

Subject: Review of Acceptable Use Policy Following AWS Migration and Personal Cloud-Storage Incident

Date: 18 September 2026

NexusTech's migration of its primary database to AWS is a material technology and operating-environment change that warrants an early review of the Acceptable Use Policy. The AUP should be checked to confirm that its rules remain clear for cloud-hosted systems, approved cloud services, remote access, data handling, monitoring and responsibility for information stored or processed in cloud environments. The migration should also trigger a review of related standards and procedures so that policy requirements remain aligned with the actual operating model.

The employee's use of a personal cloud-storage account to share a sensitive document is a second review trigger. The incident provides evidence that the existing policy language and/or awareness controls may need clarification. The review should include stakeholder consultation with IT, Security, HR, Legal/Compliance, relevant data owners and business managers; examination of the incident record, user feedback, training results and relevant access/data-sharing controls; and a risk assessment to determine whether the policy, supporting standards or procedures require changes.

I recommend two immediate AUP clarifications. First, explicitly prohibit the storage, upload or transfer of NexusTech and client information to personal cloud-storage accounts and define the approved categories of cloud services for business use. Second, expand the remote-work and data-handling requirements to state that information stored in company-approved cloud platforms remains subject to NexusTech security, access-control and classification requirements. The Information Security Manager should remain the policy owner, with the revised version routed to the Information Security Steering Committee and CEO for approval. The AUP should continue to receive an annual formal review, with early review triggered by material technology changes, significant incidents, material control failures, regulatory/contractual changes, or other evidence that the policy is no longer effective.

Security Policy Development Lifecycle – Applied Summary

Lifecycle Stage	NexusTech Application	Evidence in This Report
1. Initiation / Need Identification	Five-year-old mixed “IT Rules” document, inconsistent practices and compliance gaps establish the need for a formal framework.	Scenario analysis; hierarchy definition.
2. Stakeholder / Requirement Analysis	Consider CEO, Information Security, IT/Helpdesk, managers, HR, data owners and users.	Roles and responsibilities; communication plan.
3. Drafting	Develop policy-level requirements separately from standards, guidelines and	AUP and access procedure.

	procedures.	
4. Review / Approval	Management reviews and approves policy; operational owners validate procedures and implementation feasibility.	Approval fields; exception and governance sections.
5. Communication / Training	Use multiple communication channels and role-specific training.	Communication and Training Plan.
6. Implementation / Enforcement	Apply controls, collect evidence, monitor compliance and escalate violations.	AUP enforcement; access evidence; rollout measures.
7. Monitoring / Review	Use incidents, technology changes, metrics and risk information to trigger review.	Policy Review Memo.
8. Maintenance / Retirement	Version-control revised policies and retire superseded versions while retaining required records.	Version control and review requirements.

References

1. International Organization for Standardization (ISO). (2022). ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection — Information security management systems — Requirements. <https://www.iso.org/standard/27001>
2. National Institute of Standards and Technology (NIST). (2024). The NIST Cybersecurity Framework (CSF) 2.0 (CSWP 29). <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
3. NIST. (2024). NIST Cybersecurity Framework 2.0: Resource & Overview Guide (SP 1299). <https://csrc.nist.gov/pubs/sp/1299/final>
4. AICPA & CIMA. (2023). 2017 Trust Services Criteria (with Revised Points of Focus – 2022). <https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022>
5. NexusTech Solutions Practical Laboratory Brief. (2026). Security Policy Development Lifecycle scenario and assessment requirements. Supplied course material.